

L2 - 5.1. M365 Monitoring Basics

Task 1 - Introduction

In this room, you'll step into that investigation and learn the role of Entra ID and M365 in modern company environments by analyzing their logs!

Task 2 - What are Identity Providers

A **digital identity** is a set of attributes that uniquely represent an entity within a computer system. That entity can be a person, a device, or a software component. Identities are used to **authenticate** entities, **authorize** their access to resources, enable communication, and support actions such as accessing services or performing transactions.

Identities can be grouped into three categories:

- **Human identities:** Represent people, such as employees, contractors, partners, or customers.
- **Workload identities:** Represent software components, including applications, services, scripts, or containers, that need to authenticate to other systems.
- **Device identities:** Represent physical devices like desktops, laptops, mobile phones, and IoT devices. These identities are separate from the humans who use them.

An **Identity Provider (IdP)** is the system responsible for creating and managing these identities. It handles authentication (verifying identity), authorization (controlling access), and auditing by recording identity-related activity across connected services.

Benefits of an IdP

- **Centralized authentication and management:** All user sign-ins are handled in a single location, making it easier to manage access and investigate suspicious activity.
- **Single Sign-On (SSO):** One successful authentication grants access to multiple cloud services, improving usability while reducing password sprawl.

- **Stronger authentication:** Features such as MFA and Conditional Access can be enforced uniformly across users and applications, rather than configured per system.
- **Better visibility and logging:** Every authentication attempt generates rich identity logs, giving analysts the context needed to detect and investigate threats.

Answer the questions below

| What type of application is Entra ID?

Identity Provider

| What type of identity is a server account?

Device

Task 3 - Identities as the Target

Entra ID authenticates users and authorizes access to services like Outlook, Teams, SharePoint, and internal applications. That means a single compromised account, especially a privileged one, can give an attacker legitimate access without needing malware, local system access, or a foothold inside the network.

Attackers target cloud-based identity providers because they provide:

- **Remote access from anywhere:** Authentication occurs over the internet, so attackers don't need access to the internal network.
- **Legitimate access to multiple services via SSO:** One successful sign-in can unlock emails, files, chat, and connected apps for a user.
- **Out of the radar of traditional tools:** Firewalls and endpoint tools may see nothing suspicious because the attacker is using valid credentials or the authentication is occurring outside of their visibility.
- **Direct access to high-value resources:** Email and collaboration platforms contain sensitive data, internal communication, and often allow resetting account credentials and other authentication factors.

Common misconfigurations (or lack of configuration) that increase the risk of compromise:

- **Lack of multi-factor authentication (MFA) enforcement:** Attackers can gain access with simple stolen credentials, bypassing MFA entirely.
- **Overly permissive access policies:** Broad policies or group exclusions create gaps, allowing sign-ins from any location or exempting admin accounts from security requirements.
- **Excessive administrative privileges:** Too many admin accounts or standing privileges increase the attack surface and, if compromised, provide full tenant control.
- **Weak password policies:** Default settings may allow easily guessable passwords without protection against known breaches or common password lists.
- **Disabled authentication risk policies:** Risky authentication attempts from suspicious or locations may be permitted if security policies aren't enabled.
IPs
- **Insufficient logging and monitoring:** Without active monitoring of sign-in and audit logs, suspicious activity can persist undetected for extended periods.

Importance of Identity Logs

- Successful and failed logins
- Reasons for failed logins (e.g., bad password)
- Account lockouts
- MFA prompts and results
- Source IP address and users' geographic location
- Device and browser information
- Client/app used to authenticate (browser, mobile app, etc.).
- Conditional Access outcomes (allowed, blocked, MFA required, etc.).

Answer the questions below

What authentication resource can prevent attackers from authenticating with only a stolen password?

MFA

| What can help us detect and monitor cloud identity threats?

Logs

Task 4 - Entra ID Sign-in Logs

Microsoft Entra ID generates detailed logs for every authentication attempt, configuration change, and administrative action within a tenant. These logs don't just tell you what happened, they tell you who did it, when, where from, and often why it succeeded or failed.

Entra ID Core Components

1. Users and Sign-ins (Authentication): Every time a user attempts to authenticate to any service protected by Entra ID, a record is created. This includes successful logins, failed attempts, MFA challenges, and the context around each event (IP address, location, device, application, and others).

2. Roles and Access Decisions (Authorization): After authentication, Entra ID determines what the user is allowed to do based on their assigned roles and permissions. Changes to these roles, group memberships, or permissions are all logged in audit events.

Security Features: Entra ID includes built-in security capabilities that generate their own logs:

- **Multi-factor authentication (MFA):** Logs show whether MFA was required, prompted, satisfied, or bypassed.
- **Conditional Access policies:** These policies enforce rules like "require MFA from untrusted locations." Logs show which policies were applied and their outcomes (allowed, blocked, MFA required).
- **Identity Protection:** Entra ID's native threat detection flags risky sign-ins (impossible travel, anonymous IP, password spray) and risky users.

Exploring Entra ID Logs: To explore the Entra ID logs and investigate the alert, we will use a Splunk instance.

Sign-in Logs: The alert you are tasked to investigate mentions multiple failed authentication attempts followed by a successful login. The Sign-in logs

capture **every authentication attempt** made against a tenant. It will show you the brute force pattern and the moment the attacker succeeded!

In the Splunk instance, you can start hunting by filtering all the Sign-in (authentication) logs:

List all Sign-in events

```
index=scenario sourcetype="azure:aad:signin"
```

With this context, you can use the `errorCode` to find failure attempts and other relevant data:

List all failed Sign-ins

```
index="scenario" sourcetype="azure:aad:signin" "status.errorCode"!=0
| stats count as event_count values(ipAddress) as ip_addresses
  values(appDisplayName) as applications values(status.errorCode) as errorCodes by userPrincipalName
| sort - event_count
| table applications, userPrincipalName, ip_addresses, errorCodes, event_count
```

Error codes are a big ally when analyzing suspicious authentication alerts. They can help you to understand the stage of a credential attack the attacker is in.

Below are common error codes:

- `50126`: Invalid username or password
- `50053`: Account locked due to too many failed attempts
- `50074`: MFA required but not provided
- `50055`: Password expired

In the same query results, you can see that all failed attempts are from the same source IP in the `ipAddress` field. This is relevant information for further investigation into what this IP address has done in the tenant.

Why IPv6 Appears in Entra ID Logs

- **Native IPv6 Connections:** Microsoft services (including M365 and Azure) fully support IPv6. If an employee logs in from a mobile network (4G/5G) or a home broadband provider that uses IPv6, Entra ID records their public IPv6 address directly.
- **VPN Bypass / Split Tunneling:** If a remote user is not routed through a legacy corporate IPv4 VPN (or if split tunneling is enabled), their local ISP's IPv6 connection will hit Entra ID directly.
- **Cellular Data Devices:** Modern smartphones almost exclusively use IPv6 natively when connecting over cellular data to reach cloud services.

Now, you can filter the successful logins from this source and validate which account was compromised and the applications the attacker accessed by changing the `<ADD-IPHERE>` placeholder to the IP address you want to investigate in the following query:

List all successful Sign-ins from an IP address

```
index=scenario sourcetype="azure:aad:signin" "status.errorCode"=0 ipAddress="<ADD-IP-HERE>"
| stats values(ipAddress) as ip_addresses values(appDisplayName) as applications by userPrincipalName
| table applications, userPrincipalName, ip_addresses
```

Practice: For this task, you will answer a couple of questions regarding this suspicious authentication. With the filter `index=scenario sourcetype="azure:aad:signin"`, you will be able to see all Sign-in logs, but feel free to use any other queries you learned in this task.

Answer the questions below

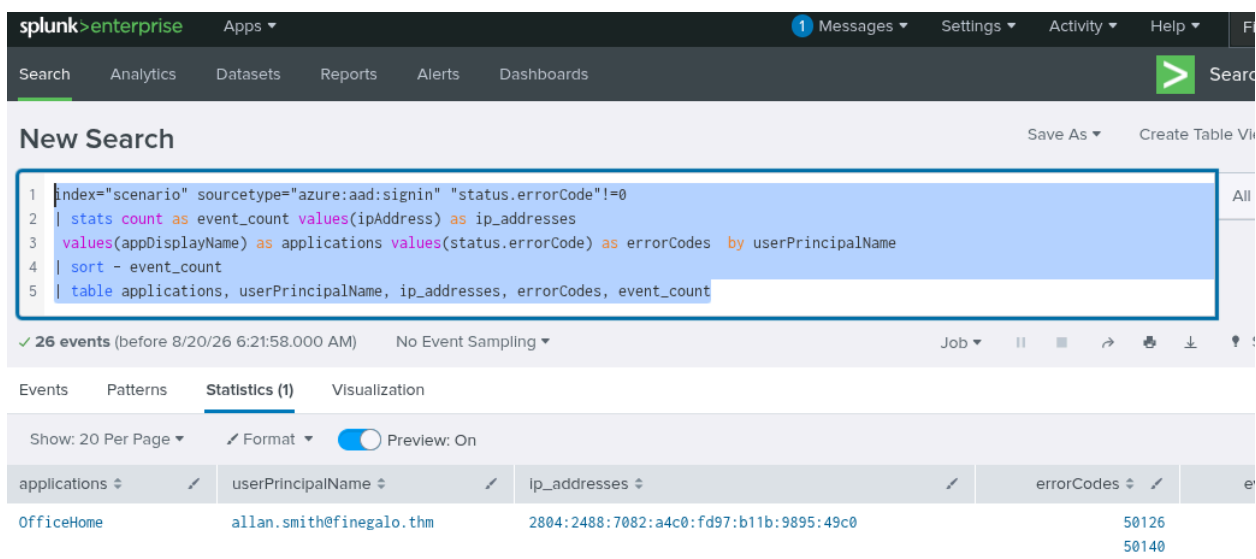
| What is the email address of the compromised identity?

allan.smith@finegalo.thm

userPrincipalName who tried to log in. In Microsoft cloud environments, this is the user's main login identifier, formatted like an email address (e.g., john.doe@company.com). appDisplayName: Represents what application the user

was trying to access. This is the readable name of the service, such as Office 365 Exchange Online, Azure Portal

```
index="scenario" sourcetype="azure:aad:signin" "status.errorCode"!=0
| stats count as event_count values(ipAddress) as ip_addresses
  values(appDisplayName) as applications values(status.errorCode) as errorCodes by userPrincipalName
| sort - event_count
| table applications, userPrincipalName, ip_addresses, errorCodes, event_count
```



The screenshot shows the Splunk Enterprise search interface. The search bar contains the following query:

```
1 index="scenario" sourcetype="azure:aad:signin" "status.errorCode"!=0
2 | stats count as event_count values(ipAddress) as ip_addresses
3   values(appDisplayName) as applications values(status.errorCode) as errorCodes by userPrincipalName
4 | sort - event_count
5 | table applications, userPrincipalName, ip_addresses, errorCodes, event_count
```

The search results are displayed in a table with the following columns: applications, userPrincipalName, ip_addresses, errorCodes, and event_count. The results show two events for the application "OfficeHome" and user "allan.smith@finegalo.thm". The IP addresses are "2804:2488:7082:a4c0:fd97:b11b:9895:49c0" and "2804:2488:7082:a4c0:fd97:b11b:9895:49c0". The error codes are "50126" and "50140".

applications	userPrincipalName	ip_addresses	errorCodes	event_count
OfficeHome	allan.smith@finegalo.thm	2804:2488:7082:a4c0:fd97:b11b:9895:49c0	50126	1
OfficeHome	allan.smith@finegalo.thm	2804:2488:7082:a4c0:fd97:b11b:9895:49c0	50140	1

What is the IP address used by the attacker?

2804:2488:7082:a4c0:fd97:b11b:9895:49c0

What is the city of the IP address used by the attacker?

Belo Horizonte

Click event, search in details

< Hide Fields All Fields Format Show: 50 Per Page View: List

a eventtype 2
 a id 25
 a index 1
 a ipAddress 1
 a isInteractive 1
 # linecount 1
 a location.city 1
 a location.countryOrRegion 1
 a location.geoCoordinates.altitude 1
 # location.geoCoordinates.latitude 1
 # location.geoCoordinates.longitude 1
 a location.state 1
 a reason 2
 a resourceDisplayName 1

location.city
 1 Value, 100% of events
 Selected Yes No
 Reports
 Top values Top values by time Rare values
 Events with this field

Values	Count	%
Belo Horizonte	26	100%

or run the query:

```
index="scenario" sourcetype="azure:aad:signin" "status.errorCode"!=0
| table application, userPrincipalName, location.city
```

When was the first successful sign-in in the compromised account after the failure attempts?

2/11/26 6:16:53.000 PM

```
index=scenario sourcetype="azure:aad:signin" "status.errorCode"=0 ipAddress="2804:2488:7082:a4c0:fd97:b11b:9895:49c0"
| table _time appDisplayName, userPrincipalName
```

splunk>enterprise Apps 1 Messages Settings Activity

Search Analytics Datasets Reports Alerts Dashboards

New Search Save As

```
1 index=scenario sourcetype="azure:aad:signin" "status.errorCode"=0 ipAddress="2804:2488:7082:a4c0:fd97:b11b:9895:49c0"
2 | table _time appDisplayName, userPrincipalName
```

✓ 30 events (before 8/20/26 6:34:49.000 AM) No Event Sampling Job ||

Events (30) Patterns **Statistics (30)** Visualization

Show: 20 Per Page Format Preview: On

_time	appDisplayName	userPrincipalName
2026-02-11 18:16:53	OfficeHome	allan.smith@finegalo.thm
2026-02-11 18:16:57	OfficeHome	allan.smith@finegalo.thm
2026-02-11 18:17:13	One Outlook Web	allan.smith@finegalo.thm
2026-02-11 18:17:13	One Outlook Web	allan.smith@finegalo.thm
2026-02-11 18:17:13	One Outlook Web	allan.smith@finegalo.thm

What is the first application the attacker accessed after the office home page?

Answer Format: The exact value of the appDisplayName field.

One Outlook Web

splunk>enterprise Apps 1 Messages Settings Activity

Search Analytics Datasets Reports Alerts Dashboards

New Search Save As

```
1 index=scenario sourcetype="azure:aad:signin" "status.errorCode"=0 ipAddress="2804:2488:7082:a4c0:fd97:b11b:9895:49c0"
2 | stats values(ipAddress) as ip_addresses values(appDisplayName) as applications by userPrincipalName
3 | table applications, userPrincipalName, ip_addresses
```

✓ 30 events (before 8/20/26 6:32:54.000 AM) No Event Sampling Job ||

Events (30) Patterns **Statistics (1)** Visualization

Show: 20 Per Page Format Preview: On

applications	userPrincipalName	ip_addresses
My Profile	allan.smith@finegalo.thm	2804:2488:7082:a4c0:fd97:b11b:9895:49c0
My Signins		
OfficeHome		
One Outlook Web		

Task 5 - Entra ID Audit Logs

After confirming a compromised account, the next step is to identify the changes the attacker made to it. This is where you should use **Audit Logs**. Audit logs capture administrative actions and changes made within the Entra ID environment. Below are some examples of post-compromise activities an attacker can perform, and you can hunt with logs:

- Resetting passwords to maintain access
- Adding new MFA methods or devices
- Assigning privileged roles to escalate access
- Modifying user attributes
- Registering malicious applications

Hunting for Post-Compromise Activity: Within the same Splunk instance, you can use the following query to filter for Entra ID audit logs and see account or environment changes:

List all Audit logs

```
index=scenario sourcetype="azure:aad:audit"
```

Each event has its own particular properties, but you should pay additional attention to the fields below, since they appear in all events and can reveal what was changed, who changed, and the target:

- **activityDisplayName** : The detailed activity or action that was performed by a user or app. All activities that generate logs are documented on this [Microsoft page \(opens in new tab\)](#). (e.g., "Change user password", "Disable account").
- **initiatedBy** : The account or app that performed the action. When the source of the action is a user account, this field contains its email address. In the case of an app, it will have the app name.
- **targetResources** : The account or object that has been changed or affected by an action.

With that context, you can query specifically for the changes related to the compromised account you found in the previous task by using its user email address and changing the **<ADD-USER-EMAIL>** placeholder in the following queries:

List changes targeting a specific user

```
index=scenario sourcetype="azure:aad:audit" targetResources
{}.userPrincipalName="<ADD-USER-EMAIL>"
| eval initiator=coalesce('initiatedBy.user.userPrincipalNam
e', 'initiatedBy.app.displayName')
| sort - _time
| table _time, initiator, activityDisplayName, result, target
Resources{}.userPrincipalName
```

List changes performed by a user

```
index=scenario sourcetype="azure:aad:audit" initiatedBy.user.
userPrincipalName="<ADD-USER-EMAIL>"
| sort - _time
| table _time, initiatedBy.user.userPrincipalName, activityDi
splayName, result, targetResources{}.userPrincipalName
```

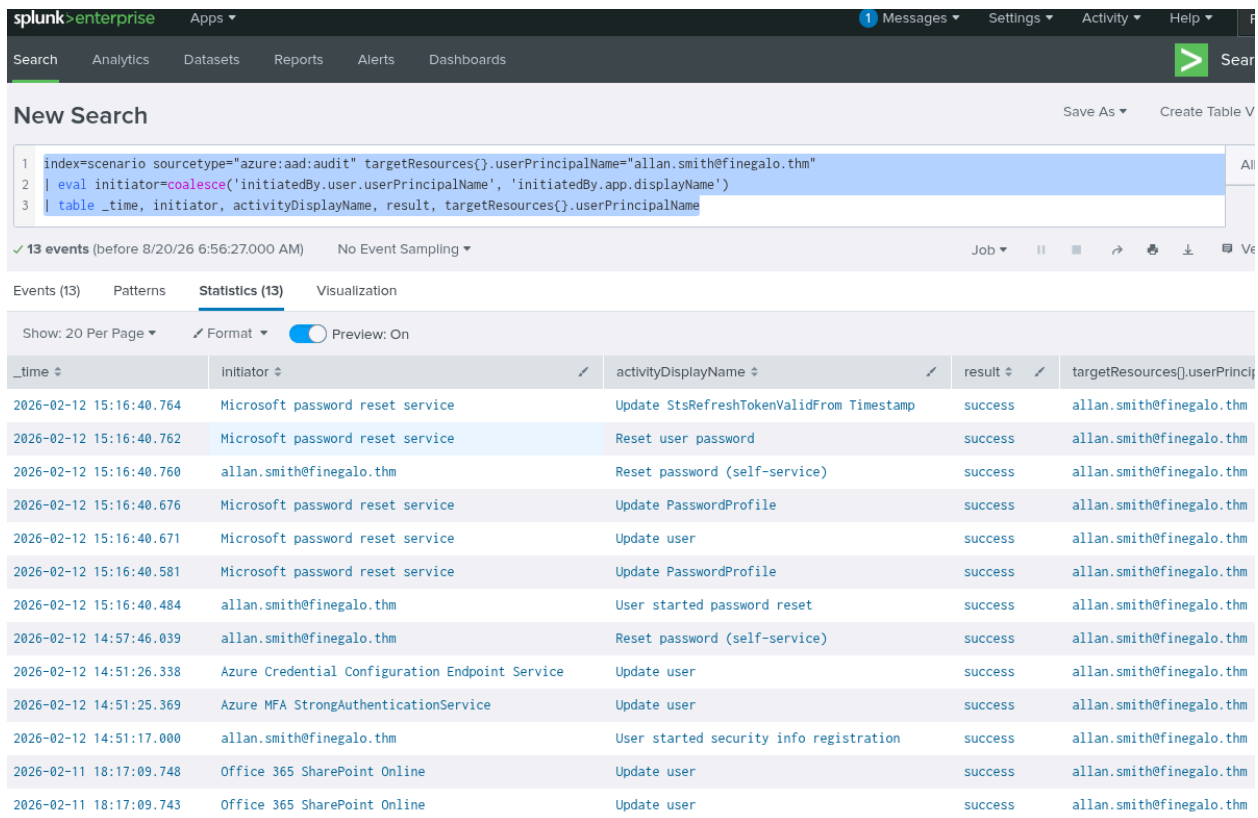
Practice: With the filter `index="scenario" sourcetype="azure:aad:audit"`, you will be able to see all Audit logs, but feel free to use any other queries you learned in this task.

Answer the questions below

What was the first change made by the attacker in the compromised user account?

User started security info registration

```
index=scenario sourcetype="azure:aad:audit" targetResources
{}.userPrincipalName="allan.smith@finegalo.thm"
| eval initiator=coalesce('initiatedBy.user.userPrincipalNam
e', 'initiatedBy.app.displayName')
| table _time, initiator, activityDisplayName, result, target
Resources{}.userPrincipalName
```



What is the `activityDisplayName` that reveals all the details of the modified properties in a user?

Update user

What is the second change made in the account?

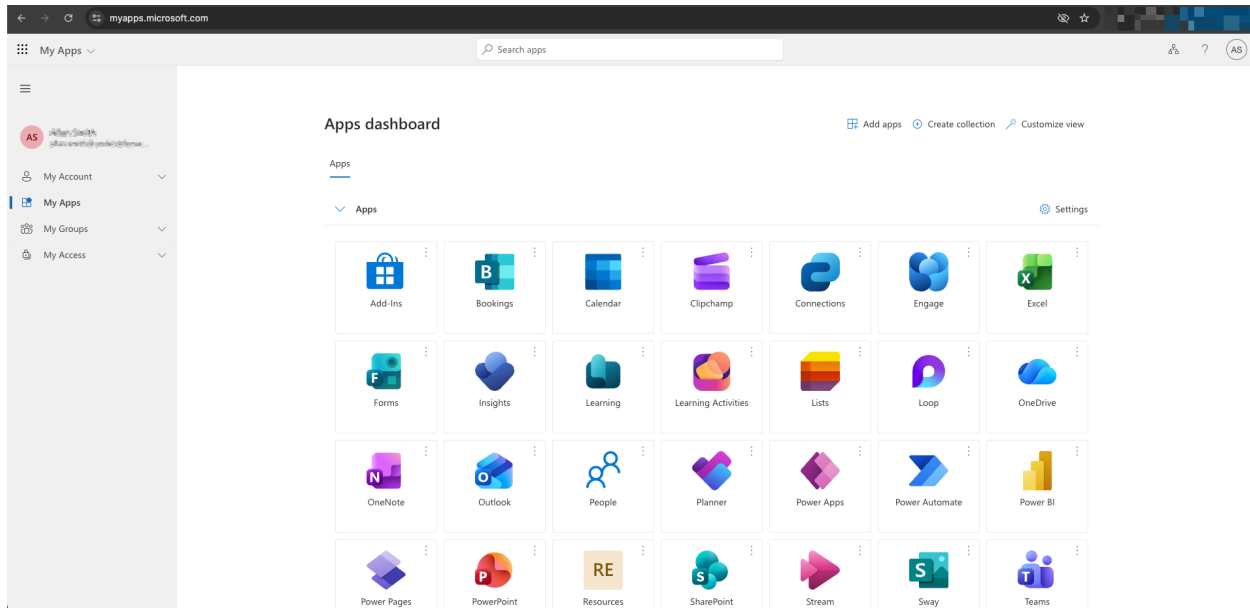
Reset password (self-service)

Task 6 - M365 Introduction

Microsoft 365 (M365) is a collection of cloud-based productivity and collaboration services tied to Entra ID identities. Once a user authenticates through Entra ID, they gain access to services like:

- **Exchange Online (Outlook):** Email, calendars, and mailbox management
- **SharePoint Online:** Document storage, file sharing, and team sites.
- **OneDrive:** Personal cloud storage.
- **Teams:** Chat, meetings, and collaboration.

- **Other services:** Power BI, Dynamics, and various Microsoft apps.



For an attacker with valid credentials, M365 services provide:

- **Access to sensitive communications:** Email contains business decisions, credentials, financial information, and confidential discussions.
- **Document repositories:** SharePoint and OneDrive store the company's intellectual property, customer data, and strategic plans.
- **Persistence mechanisms:** Mailbox rules, forwarding rules, and application permissions allow attackers to maintain access even after password changes.
- **Further credential harvesting:** Attackers can search for credentials, API keys, or sensitive information in emails and files.

M365 Relevant Logs: M365 generates detailed audit logs for user and administrative actions across all services. These logs are centralized in the **Unified Audit Log**, which captures events from Exchange, SharePoint, OneDrive, Teams, and other M365 services. Below are some key log categories relevant to investigations:

Exchange (Mailbox) Logs:

- Mailbox access and email operations (read, send, delete)
- Mailbox rule creation (often used for persistence or email exfiltration)

- Mailbox permission changes
- Forwarding rule creation

SharePoint and OneDrive Logs:

- File accessed, downloaded, or modified
- File sharing and permission changes
- Folder operations

General M365 Activity:

- Application permissions granted
- Service configurations changed
- Administrative actions performed

Task 7 - M365 Audit Logs

In the Splunk instance, you can filter M365 unified audit logs with:

List all M365 Audit logs

```
index="scenario" sourcetype="o365:management:activity"
```

Again, each event has its own specific structure, but below are key fields in M365 audit logs that appear in all log types:

- **Operation**: The specific action performed (e.g., "New-InboxRule", "FileAccessed", "Send").
- **UserId**: The account that performed the action, usually an email address.
- **ClientIP** or **ClientIPAddress**: The source IP address (Note that sometimes this information can be an Office 365 IP address. Ensure you always check the registrant for ClientIP).
- **Workload**: The M365 service where the action occurred (Exchange, SharePoint, OneDrive).
- **ObjectId**: The target resource (email address, file path, mailbox).

New Search Save As Create Table View Close

```

1 index="scenario" sourcetype="o365:management:activity"
2 | sort - _time
3 | eval sourceIP=coalesce('ClientIP', 'ClientIPAddress')
4 | table _time, Operation, UserId, sourceIP, Workload, Objectid

```

✓ 6 events (before 2/13/26 7:03:26.000 PM) No Event Sampling Job Smart Mode

Events Patterns **Statistics (6)** Visualization

Show: 20 Per Page Format Preview: On

_time	Operation	UserId	sourceIP	Workload	Objectid
2026-02-11 18:20:09	MailItemsAccessed	[REDACTED]	[REDACTED]	Exchange	[REDACTED]
2026-02-11 18:19:47	MailItemsAccessed	[REDACTED]	2603:10a6:150:1e5::20	Exchange	[REDACTED]
2026-02-11 18:19:39	Send	[REDACTED]	[REDACTED]	Exchange	[REDACTED]
2026-02-11 18:18:46	Create	[REDACTED]	[REDACTED]	Exchange	[REDACTED]
2026-02-11 18:18:10	New-InboxRule	[REDACTED]	[REDACTED]	Exchange	[REDACTED]
2026-02-11 18:17:37	Set-Mailbox	[REDACTED]	[2603:1026:c0a:1042::5]:22007	Exchange	[REDACTED]

Microsoft IP Addresses

Hunting for Post-Compromise M365 Activities: For your investigation into M365 logs, identifying suspicious activities on the compromised account is essential. You will further explore these attackers' techniques in this module. For now, here are some common post-compromise activities you should be aware of:

Mailbox Manipulation:

- Creation of inbox rules to delete, forward, or move emails
- Mass email deletion or moves to the deleted items
- Emails sent to external addresses
- Access from unusual IP addresses or locations

File Operations:

- Mass file downloads from SharePoint or OneDrive
- Access to sensitive or executive-level documents
- File sharing to external domains
- Downloads of files the user wouldn't normally access

Below is an enhanced Splunk query that might help you as a starting point to identify what the attacker did with the user account you found in task 4 by replacing the `<ADD-USER=EMAIL>` placeholder:

List actions performed by a user

```

index="scenario" sourcetype="o365:management:activity" UserId
=<ADD-USER-EMAIL>"
| sort - _time
| eval sourceIP=coalesce('ClientIP', 'ClientIPAddress')
| table _time, Operation, UserId, sourceIP, Workload, ObjectI
d

```

Practice: With the filter `index="scenario" sourcetype="o365:management:activity"`, you will be able to see all M365 audit logs, but feel free to use any other queries you learned in this task.

Answer the questions below

| What is the application used by the attacker?

Exchange

```

index="scenario" sourcetype="o365:management:activity" UserId
="allan.smith@finegalo.thm"
| sort - _time
| eval sourceIP=coalesce('ClientIP', 'ClientIPAddress')
| table _time, Operation, UserId, sourceIP, Workload, ObjectI
d

```

```

1 index="scenario" sourcetype="o365:management:activity" UserId="allan.smith@finegalo.thm"
2 | sort - _time
3 | eval sourceIP=coalesce('ClientIP', 'ClientIPAddress')
4 | table _time, Operation, UserId, sourceIP, Workload, ObjectID

```

✓ 5 events (before 8/20/26 7:21:22.000 AM) No Event Sampling ▼

Events (5) Patterns **Statistics (5)** Visualization

Show: 20 Per Page ▼ Format Preview: On

_time	Operation	UserId	sourceIP	Workload
2026-02-11 18:20:09	MailItemsAccessed	allan.smith@finegalo.thm	2804:2488:7082:a4c0:fd97:b11b:9895:49c0	Exchange
2026-02-11 18:19:47	MailItemsAccessed	allan.smith@finegalo.thm	2603:10a6:150:1e5::20	Exchange
2026-02-11 18:19:39	Send	allan.smith@finegalo.thm	2804:2488:7082:a4c0:fd97:b11b:9895:49c0	Exchange
2026-02-11 18:18:46	Create	allan.smith@finegalo.thm	2804:2488:7082:a4c0:fd97:b11b:9895:49c0	Exchange
2026-02-11 18:18:10	New-InboxRule	allan.smith@finegalo.thm	[2804:2488:7082:a4c0:fd97:b11b:9895:49c0]:16321	Exchange

What is the change made in the user application by the attacker?

New-InboxRule

What is the subject of the email message sent by the attacker?

URGENT: Approval for new internal VPN Access

```
index="scenario" sourcetype="o365:management:activity" UserId="allan.smith@finegalo.thm"
```

```

2
a Folders().FolderItems().Id 2
a Folders().FolderItems().ImmutableId 2
a Folders().FolderItems().InternetMessageId 2
a Folders().FolderItems().SizeInBytes 2
a Folders().FolderItems().Subject 2
a Folders().Id 2
a Folders().Path 2
a Force 1
a From 1
a HostAppId 1
a Id 5
a Index 1

```

Folders().FolderItems().Subject

2 Values, 40% of events

Selected Yes No

Reports

Top values Top values by time Rare values

Events with this field

Values	Count	%
URGENT: Approval for new internal VPN Access	2	100%
Re: URGENT: Approval for new internal VPN Access	1	50%

When did the attacker access the response to the message?

2/11/26 6:20:09.000 PM

Which path was the response stored in?

\Deleted Items

```
1 index="scenario" sourcetype="o365:management:activity" UserId="allan.smith@finegalo.thm"
2 | sort - _time
3 | table _time, Operation, Item.Subject, Folders{}.Path, Parameters{}.Name
```

✓ 5 events (before 8/20/26 7:30:17.000 AM) No Event Sampling ▾ Job ▾

Events (5) Patterns **Statistics (5)** Visualization

Show: 20 Per Page ▾ Format ▾ Preview: On

_time ↕	Operation ↕	Item.Subject ↕	Folders{}.Path ↕
2026-02-11 18:20:09	MailItemsAccessed		\Deleted Items \Sent Items
2026-02-11 18:19:47	MailItemsAccessed		\Sent Items
2026-02-11 18:19:39	Send	URGENT: Approval for new internal VPN Access	
2026-02-11 18:18:46	Create	Approval for VPN Access	
2026-02-11 18:18:10	New-InboxRule		

Task 8 - Conclusion

- Learned why attackers target Entra ID and M365, and the common gaps they exploit.
- Learned that the real power of these log sources lies in correlating them to build a complete timeline of an attack.
- Understand that Entra ID Sign-in logs are the investigation starting point to identify:
 - Suspicious authentication attempts.
 - If an attacker successfully authenticates.
 - The location from which the authentications are coming.
- Understand that Entra ID Audit logs help you to identify privilege escalation or persistence at the identity level.

- Understand that M365 Audit logs help you to identify what the attacker did with legitimate access in the company's applications, such as Outlook, SharePoint, and others.